Gobierno de la Ciberseguridad y Análisis de Riesgos

Tema 10. Respuesta y monitorización

Índice

Esquema

Ideas clave

10.1. Introducción y objetivos

10.2. Respuesta y mitigación del riesgo

10.3. Monitoreo y reporte de riesgos y controles

10.4. Referencias bibliográficas

A fondo

IMC_01 - Metodología de evaluación de Indicadores para Mejora de la Ciberresiliencia (IMC)

IMC_02 - Diccionario de Indicadores para Mejora de la Ciberresiliencia (IMC)

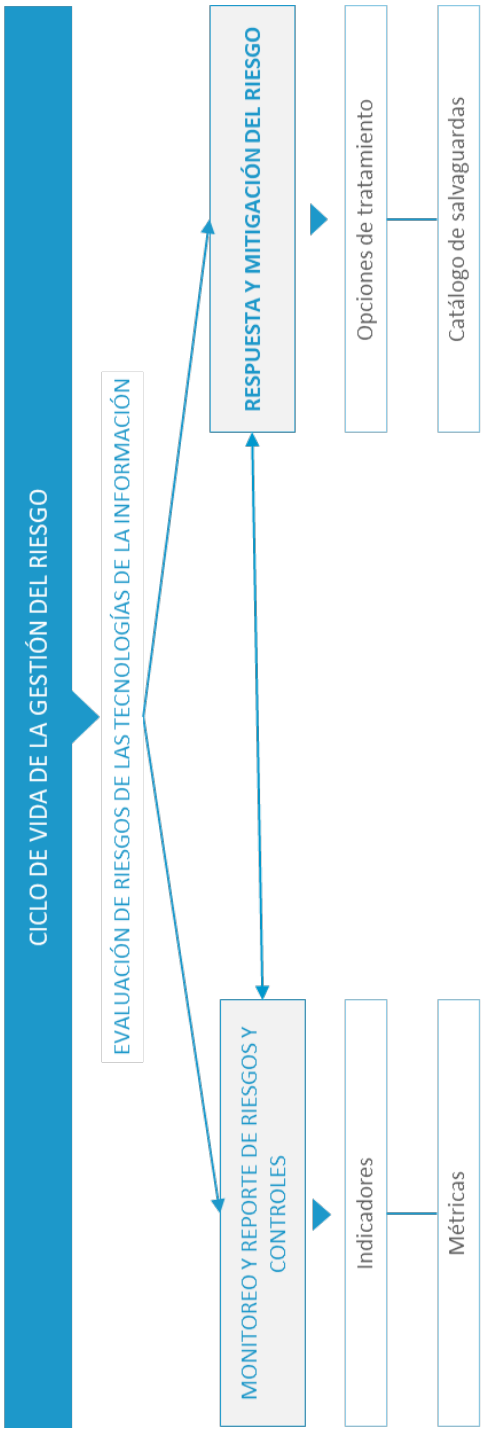
Guía de seguridad (CCN-STIC-815) esquema nacional de seguridad métricas e indicadores

Guía de seguridad de áreas críticas para la computación en la nube v4.0

Modelo para la mitigación de vulnerabilidades informáticas en los servicios web

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

10.1. Introducción y objetivos

El objetivo fundamental de esta unidad es conocer cómo se puede responder y mitigar un riesgo, así como la necesidad de monitorizar y de medir el estado y evolución del riesgo.

Este tema abordará distintas cuestiones relativas a la respuesta, mitigación y monitorización de los riesgos y profundizará en distintos aspectos considerados relevantes para realizar estas actividades.

Los principales objetivos de este tema son los siguientes:

- Conocer las distintas actividades y tareas para la respuesta y monitorización de riesgos de TI.
- Definir indicadores de gestión del riesgo.

Con la finalidad de alcanzar los objetivos propuestos, este tema se ha estructurado en dos bloques, uno dedicado a la respuesta y mitigación y otro al monitoreo y reporte de los riesgos.

© Universidad Internacional de La Rioja (UNIR)

10.2. Respuesta y mitigación del riesgo

Las organizaciones para dar una respuesta a los riesgos en tecnologías de la información (TI) a los que están expuestos, que han sido identificados, analizados y valorados mediante un proceso de evaluación del riesgo, deben efectuar su tratamiento mediante un proceso de tratamiento del riesgo que, de acuerdo con la norma ISO 31000, implica la selección y la implementación de una o varias opciones para modificar dichos riesgos.

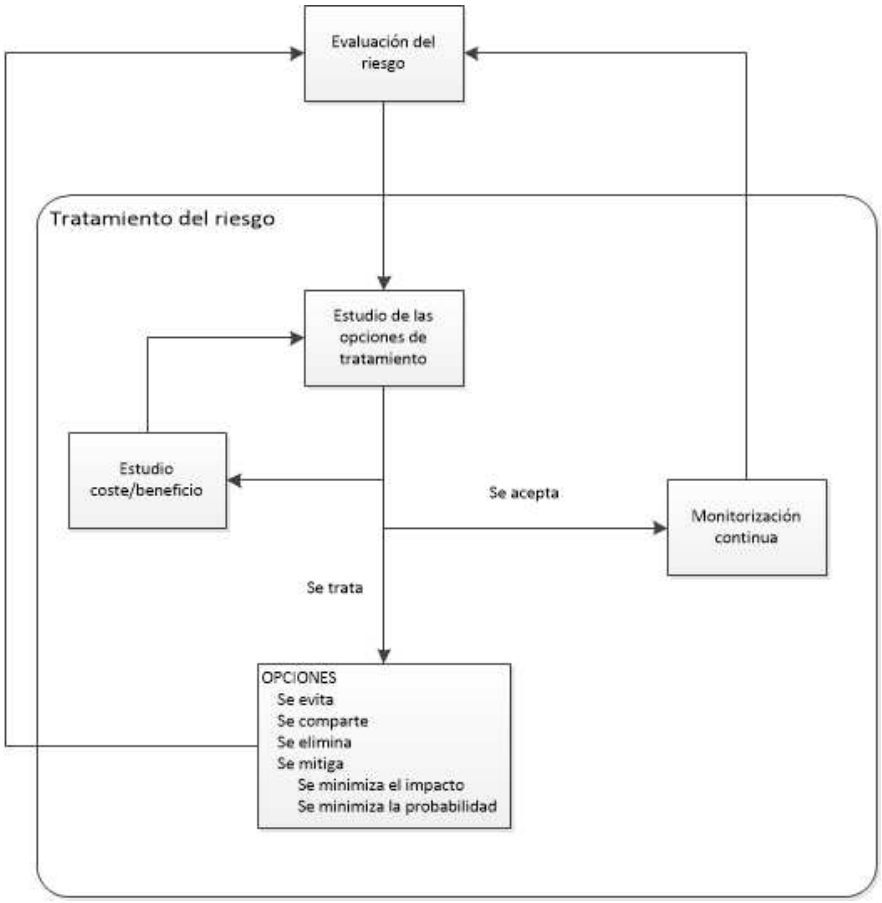


Figura 1. Tratamiento del riesgo según la ISO 31000.Fuente: elaboración propia.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

De acuerdo con la norma ISO 31000 las opciones de tratamiento no se excluyen necesariamente unas a otras, no son apropiadas en todas las circunstancias y están compuestas por algunas de las siguientes acciones:

- Evitar el riesgo decidiendo no iniciar o continuar con la actividad que causa el riesgo.
- Aceptar o aumentar el riesgo a fin de perseguir una oportunidad.
- Eliminar la fuente del riesgo.
- Modificar la probabilidad.
- Modificar las consecuencias.
- Compartir el riesgo.
- Retener el riesgo en base a una decisión informada.

Mitigación del riesgo

Cuando hablamos de **mitigación del riesgo** nos estamos refiriendo a una de las dos opciones de tratamiento del riesgo siguientes: minimizar el impacto o minimizar la probabilidad, o a las dos en conjunto. Recordemos que las opciones de tratamiento del riesgo no se excluyen necesariamente unas a otras, ni son apropiadas en todas las circunstancias. **Minimizar el impacto** se puede lograr tanto reduciendo la degradación del activo causada por la materialización de la amenaza como reduciendo sus consecuencias sobre la organización. También se utiliza la expresión «acotar el impacto». Minimizar la probabilidad no es otra cosa que disminuir las posibilidades de ocurrencia de eventos que supongan la materialización de una amenaza.

© Universidad Internacional de La Rioja (UNIR)

En ambos casos, minimizar el impacto y minimizar la probabilidad, por lo tanto, para mitigar el riesgo lo que hay que hacer es ampliar o mejorar el conjunto de controles, de salvaguardas y de medidas de seguridad. Si hablamos en términos de **madurez de las salvaguardas** lo que hay que hacer es mejorar su nivel de madurez.

Para mitigar los riesgos a los que está expuesto un sistema de información, se requiere una combinación de salvaguardas de diferentes tipos. La selección de estas debe ser equilibrada y se debe tener en cuenta el tipo de activo a proteger, el propio valor del activo y el valor de los que dependen de él, así como las amenazas a las que está expuesto el sistema de información.

Los controles, las salvaguardas y las medidas de seguridad nos permiten hacer frente a las amenazas a las que estamos expuestos, pero hay que tener en cuenta que las salvaguardas, especialmente las técnicas, varían con el avance tecnológico, debido a que continuamente:

- Aparecen tecnologías nuevas.
- Van desapareciendo tecnologías antiguas.
- Cambian los tipos de activos a considerar.
- Aparecen nuevas amenazas.
- Evolucionan las capacidades de los atacantes.
- Evoluciona el catálogo de salvaguardas disponibles.

En consecuencia, el **catálogo de salvaguardas que** se muestra en la tabla siguiente no es un catálogo de medidas de seguridad, de procedimientos o de productos a instalar, se trata de un listado de salvaguardas genéricas, clasificadas taxonómicamente sin llegar a establecer las concreciones materiales, tecnológicas, organizativas y procedimentales que se apliquen en cada momento.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Catálogo de Salvaguardas	
Activo	**Salvaguarda**
Datos/Información	Copias de seguridad de los datos *(backup)*
	Cifrado de la información
	Uso de firma electrónica
Claves criptográficas	Uso de servicios de sellado de tiempo
	Gestión de claves de firma de información
	Gestión de claves para contenedores criptográficos
	Gestión de claves de comunicaciones
	Gestión de certificados

Catálogo de Salvaguardas	
Activo	**Salvaguarda**
Servicios	Aseguramiento de la disponibilidad
	Aceptación y puesta en operación
	Se aplican perfiles de seguridad
	Explotación
	Gestión de cambios (mejoras y sustituciones)
	Terminación
	Protección de servicios y aplicaciones web
	Protección del correo electrónico
	Protección del directorio
	Protección del servidor de nombres de dominio
	Teletrabajo
	Voz sobre IP

© Universidad Internacional de La Rioja (UNIR)

Catálogo de Salvaguardas	
Activo	**Salvaguarda**
Equipos *(hardware)*	Puesta en producción
	Se aplican perfiles de seguridad
	Aseguramiento de la disponibilidad
	Operación
	Cambios (actualizaciones y mantenimiento)
	Terminación
	Informática móvil

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Catálogo de Salvaguardas	
Activo	**Salvaguarda**
Comunicaciones	Entrada en servicio
	Se aplican perfiles de seguridad
	Aseguramiento de la disponibilidad
	Autenticación del canal
	Protección de la integridad de los datos intercambiados
	Protección criptográfica de la confidencialidad de los datos intercambiados
	Operación
	Cambios (actualizaciones y mantenimiento)
	Terminación
	Internet: uso y acceso
	Seguridad Wireless (WiFi)
	Telefonía móvil
	Segregación de las redes en dominios
Organización	Organización
	Gestión de riesgos
	Planificación de la seguridad
	Inspecciones de seguridad

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Catálogo de Salvaguardas	
Activo	**Salvaguarda**
Interconexiones	Puntos de interconexión: conexiones entre zonas de confianza
	Sistema de protección perimetral
	Protección de los equipos de frontera
Soportes	Aseguramiento de la disponibilidad
	Protección criptográfica del contenido
	Limpieza de contenidos
	Destrucción
Elementos auxiliares	Aseguramiento de la disponibilidad
	Instalación
	Suministro eléctrico
	Climatización
	Protección del cableado
Instalaciones	Diseño
	Defensa en profundidad
	Control de los accesos físicos
	Aseguramiento de la disponibilidad
	Terminación

© Universidad Internacional de La Rioja (UNIR)

Catálogo de Salvaguardas	
Activo	**Salvaguarda**
Personal	Gestión del Personal
	Formación y concienciación
	Aseguramiento de la disponibilidad
Operaciones	Prevención y reacción frente a desastres
	Continuidad del negocio
	Análisis de impacto
	Plan de Recuperación de Desastres
Externalización	Relaciones Externas
	Acuerdos para intercambio de información y software
	Acceso externo
	Servicios proporcionados por otras organizaciones
	Personal subcontratado
Adquisición y desarrollo	Servicios: Adquisición o desarrollo
	Aplicaciones: Adquisición o desarrollo
	Equipos: Adquisición o desarrollo
	Comunicaciones: Adquisición o contratación
	Soportes de Información: Adquisición
	Productos certificados o acreditados

Tabla 1. Catálogo de salvaguardas. Fuente: elaboración propia.

Actuación de las salvaguardas

De acuerdo con su forma de actuación, las salvaguardas se pueden clasificar en dos tipos: **salvaguardas preventivas** y **salvaguardas reactivas.**

Las primeras actúan reduciendo la probabilidad de materialización de las amenazas, para ello deben reducir las oportunidades de que un incidente ocurra y las segundas

© Universidad Internacional de La Rioja (UNIR)

cuando limitan el impacto causado por la materialización de una amenaza, cuando acotan las consecuencias de un incidente.

Eficacia de las salvaguardas

Para poder determinar la eficacia de una salvaguarda es necesario conocer su grado de implantación, lo que implica conocer cómo está configurada la medida de seguridad en la actualidad en términos de perfeccionamiento o alcance e incluso teniendo en cuenta el grado de conocimiento de esta por parte de las personas implicadas en su buen funcionamiento.

La combinación del grado de implantación de la medida de seguridad concreta con la eficacia intrínseca de esta para proteger de determinadas amenazas determinará el su grado de eficacia real de la medida de seguridad y por lo tanto su capacidad para disminuir el riesgo inherente.

Por eficacia intrínseca de una salvaguarda entendemos el grado de protección que proporciona una salvaguarda contra una amenaza concreta cuando su grado de implantación es total y su eficacia es la máxima que permite su diseño y la tecnología disponible.

Para valorar el grado de implantación de las salvaguardas tenemos dos opciones, en porcentaje o en base a un **modelo de madurez.**

© Universidad Internacional de La Rioja (UNIR)

Nivel de madurez de las salvaguardas	
0	▸ La medida no está implantada.
1	▸ La implantación de la medida presenta graves deficiencias por obsolescencia o falta de mantenimiento
2	▸ La medida está instalada pero su actualización y/o mantenimiento no son adecuados y permanentes. Depende de otras medidas clasificadas en este nivel.
3	▸ La medida está instalada. Abarca a la mayor parte de la infraestructura, pero no toda. ▸ El desconocimiento de algunas personas con relación en la medida disminuye su eficacia. ▸ Depende de otras medidas clasificadas en este nivel.
4	▸ La medida de seguridad está completamente desplegada e implantada en su desarrollo y aplicación que no la conocen lo suficiente. ▸ En otros casos puede que la medida dependa de otras clasificadas en este nivel.
5	▸ La medida de seguridad está completamente desplegada, implantada y probada. ▸ Todas las personas que tienen alguna relación activa con la misma han recibido información suficiente para que la medida pueda proporcionar toda su eficacia. ▸ La protección proporcionada por esta medida no depende de ninguna otra o depende de otras con este mismo grado de implantación.

Tabla 2. Nivel de madurez de las salvaguardas. Fuente: Elaboración propia.

© Universidad Internacional de La Rioja (UNIR)

A continuación, se muestra una matriz de ejemplo para el cálculo de la eficacia real de una salvaguarda:

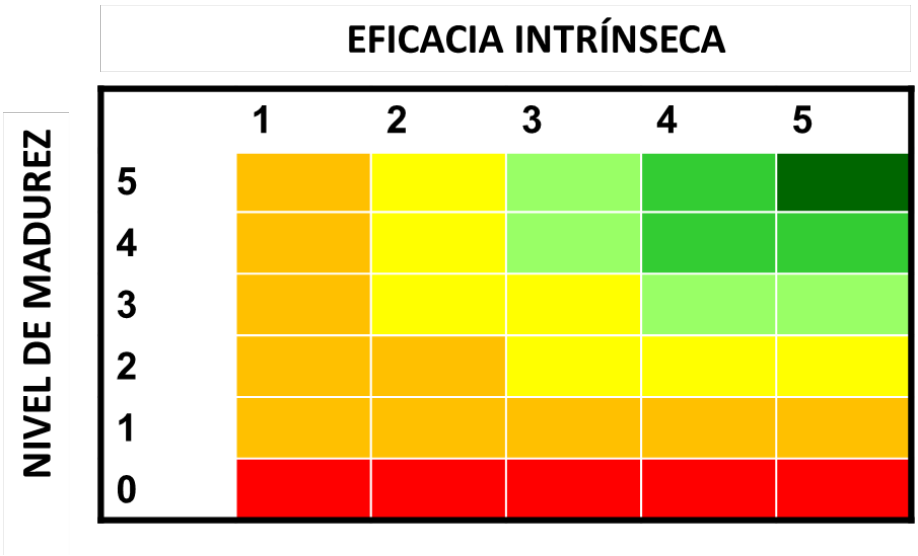


Tabla 3. Matriz de ejemplo para el cálculo de la eficacia real de una salvaguarda. Fuente: elaboración propia.

© Universidad Internacional de La Rioja (UNIR)

10.3. Monitoreo y reporte de riesgos y controles

La evaluación de riesgos es un proceso formalmente establecido que se basa en múltiples estimaciones y valoraciones que en algunos casos puede que no reflejen exactamente la realidad o que con el transcurso del tiempo dichas estimaciones o valoraciones se alejen de la situación real de los riesgos objeto de la evaluación. Por ello, es absolutamente necesario que el sistema de información y comunicaciones sea objeto de una que hemos evaluado monitorización permanente, para poder detectar aquellos cambios en los contextos externo e interno, así como en el comportamiento humano, que puedan influir en los riesgos a los que está expuesta la organización y, por lo tanto, también sus sistemas de información y comunicaciones.

Medir y evaluar el desempeño de los procesos de un sistema de información y comunicaciones nos permite analizar, comprender y controlar mejor su funcionamiento, lo que nos servirá para predecir tanto su comportamiento como el de los riesgos a los que está expuesto, así como mejorar su eficiencia y eficacia.

Tenemos que distinguir entre medidas, métricas e indicadores.

Una **medida** proporciona una indicación cuantitativa de la extensión, cantidad, dimensiones, capacidad o tamaño de algunos atributos de un elemento. En nuestro caso mediremos factores que nos permitan evaluar el comportamiento de los riesgos, lo que implica evaluar las amenazas y las salvaguardas.

Una **métrica** es una medida cuantitativa del grado en que un sistema, componente o proceso posee un atributo dado. Las métricas nos van a permitir relacionar y comparar las mediciones que realicemos, medir de forma objetiva y especificar en el mundo formal la correspondencia de un atributo del mundo real, además de servir como base para la utilización de métodos cuantitativos de evaluación y predicción.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Un **indicador de riesgos** es una **métrica o combinación de varias** métricas que nos van a permitir conocer en profundidad el comportamiento de los riesgos, lo que implica conocer en profundidad la evolución y potencialidad de las amenazas existentes o emergentes, así como la aplicabilidad y efectividad de las salvaguardas implantadas.

Los indicadores deben reunir las siguientes características:

- Específicos.
- Medibles.
- Alcanzables.
- Realistas.
- A tiempo.

Los indicadores de riesgos nos sirven de base tanto para cuantificar los riesgos a los que está expuesto el sistema de información y comunicaciones, como para la utilización de métodos cuantitativos de evaluación y predicción que nos permitan anticiparnos a los riesgos. Además, son un elemento clave que da **soporte a la toma de decisiones,** permitiéndonos:

- Medir la evolución de amenazas actuales y emergentes.
- Medir la efectividad de las salvaguardas implantadas.
- Medir la capacidad o habilidad de la organización en las tareas de seguridad.
- Obtener datos relevantes sobre el estado de seguridad de la organización.
- Saber dónde hay que hacer hincapié en la mejora de la seguridad.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Para diseñar e implantar un conjunto de métricas e indicadores de riesgos, es necesario realizar las siguientes tareas y actividades:

- Determinar las **entidades a medir:** una entidad es un objeto que va a ser caracterizado mediante una medición de sus atributos. Una entidad puede ser tanto tangible como intangible, en nuestro caso un riesgo, puede ser una entidad intangible y una salvaguarda puede ser una entidad tangible.

- Determinar lo **atributos a medir:** un atributo es una propiedad mensurable, física o abstracta, de una entidad. El atributo puede ser interno o externo y se puede medir (cuantificar) por medio de una métrica directa o indirecta.

- Determinar los **conceptos medibles:** un concepto medible es una relación abstracta entre atributos de una o más entidades y una necesidad de información.

- **Definir las métricas:** una métrica es un método de medición definido y una escala de medición aplicable que establece una correspondencia de un dominio empírico (mundo real) a un mundo formal, matemático. La medida incluye al valor numérico o nominal asignado al atributo de un ente por medio de dicha correspondencia.

Lo que no se mide no se puede mejorar. Por ello, necesitamos conocer periódicamente la evolución de los riesgos a los que está expuesto el sistema de información y comunicaciones de la organización, y si las salvaguardas que tenemos implantadas están funcionando como se espera; para ello, debemos definir una serie de indicadores que nos ayude a realizar las mediciones.

Los **indicadores de impacto y riesgo potenciales** son muy útiles a la hora de decidir qué elementos y factores deben ser objeto de monitorización. Se debe diseñar e implantar un sistema de alerta temprana que nos permita detectar de forma precoz los posibles incidentes; para ello, puede ser útil utilizar indicadores predictivos, así como un sistema de respuesta a incidentes de seguridad que nos permita hacer frente a los riesgos a los que está expuesto el sistema de información

© Universidad Internacional de La Rioja (UNIR)

y comunicaciones y que, en caso de incidentes, nos permita comunicar la situación y evolución de estos a todas las partes interesadas.

Es necesario elaborar un conjunto de indicadores clave de riesgo *(KRI or Key Risk Indicators).* Al elaborarlos, es imprescindible que se definan con exactitud, para cada uno de ellos, las siguientes características:

- En qué medidas se basan.
- Cuál es el algoritmo de cálculo.
- La periodicidad de evaluación.
- Los umbrales de aviso y alarma.

Debemos ser capaces de elaborar un **cuadro de mando de indicadores de riesgos** en un lenguaje que tenga sentido para el negocio y hacerlo como parte indispensable del modelo de gestión de riegos que se haya implantado en la organización, para que, de este modo, las métricas estén alineadas con el negocio, aporten un valor añadido y ayuden a gestionar y controlar los riesgos a los que está expuesto el sistema de información de la organización.

Realizar mediciones persigue, entre otros, los siguientes objetivos:

- Evaluar la efectividad de la implementación de las salvaguardas.
- Evaluar la peligrosidad de las amenazas actuales y emergentes.
- Mejorar la respuesta a los riesgos.
- Ser una ayuda a la evaluación de riesgos y al plan de tratamiento de riesgos.

Un cuadro de mando de riesgos nos servirá para medir la efectividad de las salvaguardas implantadas y el nivel de riesgo al que está expuesto el sistema de información de la organización. Al final, los indicadores nos deben proporcionar

© Universidad Internacional de La Rioja (UNIR)

resultados comparables y reproducibles. Cuando se diseñen e implanten los indicadores, se debe especificar la amenaza, el proceso o salvaguarda que sea objeto de monitorización, el responsable del análisis de datos, la periodicidad de control y los valores mínimos (límite admisible) y esperados (valor objetivo) de cada indicador.

La **responsabilidad** de monitorizar un riesgo recae en su propietario, sin perjuicio de que la función pueda ser delegada en el día a día, retomando el control de la situación cuando haya que tomar medidas para atajar un riesgo que se ha salido de los márgenes tolerables. Cada vez que la realidad difiere de nuestras estimaciones conviene hacer un ciclo de revisión del análisis y las decisiones de tratamiento.

Elaboración de las métricas

A la hora de elaboran las métricas es necesario definir los métodos de medición, la escala y los indicadores, además de tener en cuenta que existen dos tipos de métricas, las directas y las indirectas.

Una **métrica directa** es la métrica de un atributo que no depende de ninguna métrica de otro atributo. Una **métrica indirecta** es aquella métrica de un atributo que se deriva de una o más métricas de otros atributos y que se formaliza por medio de una función de medición, que no es otra cosa que un algoritmo que permite combinar dos o más métricas.

Un método de medición es una secuencia lógica de operaciones expresadas de forma genérica, que permite elaborar una descripción de actividad. El tipo de método de medición va a depender de la naturaleza de las operaciones utilizadas para cuantificar el atributo. Y se pueden distinguir dos tipos:

- Subjetivo: cuando la cuantificación supone un juicio realizado por un ser humano.
- Objetivo: cuando la cuantificación está basada en métodos numéricos.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Una **escala** es un conjunto de valores con propiedades definidas. Las escalas pueden ser cualitativas o numéricas, continuas o discretas, aritméticas o logarítmicas. Existen diferentes tipos de escalas y cada uno de estos tipos determina las transformaciones admisibles, el tipo de operaciones matemáticas y los análisis estadísticos que pueden aplicarse sobre el conjunto de valores de la escala.

Un **indicador** es un método de cálculo y una escala definida con un modelo y criterios de decisión que tienen por objeto proveer una evaluación o estimación de un concepto medible con respecto a una necesidad de información. Las métricas por si solas no pueden interpretar un concepto medible; para poder llevar a cabo esta interpretación hacen falta indicadores.

A la hora de elaborar una métrica es conveniente utilizar un formulario que, como mínimo, debe contemplar los siguientes campos:

- Metas: definen los resultados deseados en la implantación de uno o varios objetivos de control o técnicas que son medidos por la métrica.
- Objetivos: definen las acciones que se requieren para alcanzar las metas fijadas.
- Métrica: describe la medida cuantitativa proporcionada por la métrica. Utiliza una definición numérica que comienza con las palabras «porcentaje», «número», «media» u otros términos similares.
- Propósito: describe la funcionalidad obtenida recogiendo la métrica. Incluye si la métrica será utilizada como medida interna o para preparar informes, qué visibilidad se espera obtener con esta métrica y razones legales para recoger métricas específicas si existen o información similar.
- Evidencia de la implantación: prueba de la existencia de controles que validan la implantación. Esta información se utiliza para calcular la métrica que valida que la actividad se ha realizado y como factor causal que puede señalar las causas de los resultados.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

- Frecuencia: periodos de tiempo propuestos para recoger los datos que se utilizan para medir los cambios producidos.
- Fórmula: describe el cálculo que debe realizarse y que proporciona los resultados numéricos de la métrica.
- Origen de los datos: relación de la ubicación de los datos utilizados para calcular la métrica. Incluye bases de datos, herramientas de seguimiento, organizaciones o roles específicos dentro de la organización que pueden proporcionar información.
- Indicadores: indicadores a los que se encuentra asociada la métrica. Proporciona información acerca del significado de la métrica y su tendencia. Señalan posibles causas de tendencias identificadas mediante medidas y posibles soluciones para corregir el defecto. Define si el objetivo ha sido alcanzado mediante la métrica e indica qué tendencia debería ser considerada positiva con relación al objetivo fijado.

© Universidad Internacional de La Rioja (UNIR)

Un ejemplo de cómo se podría definir una métrica para una salvaguarda es el siguiente:

	Medida	Nombre de la métrica
	Valor	Define la cantidad medida como un porcentaje, un número, una frecuencia, coeficiente, diferencia, etc.
	Tipo	Tipo de control al que se refiere la métrica. Puede ser de despliegue, de eficacia, de eficiencia, etc.
	Propósito	Objetivo que se persigue con esta métrica
	Cliente	Público objetivo de la métrica
	Método de medida	Define el método utilizado en la medida, la función de cálculo o el modelo de análisis
	Procedimiento	Define el método de recolección de datos utilizado en la métrica
Personas a cargo	Propietario	Persona o unidad organizativa que usará la métrica
	Peticionario	Persona o unidad organizativa responsable de solicitar las variables
	Entrada	Persona o unidad organizativa responsable de recomer y almacenar la información sobre los atributos o entidades sujetas a medida
	Comunicación	Persona o unidad organizativa responsable de comunicar la medida
	Revisión	Persona o unidad organizativa responsable de aplicar los criterios de evaluación sobre la métrica para verificar su validez y confiabilidad respecto del control de seguridad

© Universidad Internacional de La Rioja (UNIR)

Ciclo de vida	Frecuencia de obtención	Período de tiempo que transcurre entre la recogida de distintos datos.
		Período de tiempo de almacenamiento del dato
	Periodicidad de la entrada	Fecha en la que se obtiene el dato
	Fecha de obtención	Fecha de expiración de la validez de la métrica
	Fecha de validez	Periodo de tiempo que transcurre desde la recogida de datos
	Criterios	Criterios para la medida
	Alcance o dominio	Define el ámbito al que se circunscriben los datos que se van a recabar (una máquina específica, un servicio, un grupo de recursos, una red, un edificio, un departamento o grupo, una unidad de negocio, etc.)

Tabla 4. Ejemplo de cómo definir una métrica. Fuente: elaboración propia.

© Universidad Internacional de La Rioja (UNIR)

10.4. Referencias bibliográficas

International Organization for Standardization. (2018). *Risk management — Principles and guidelines* (estándar ISO/IEC 31000:2018). www.iso.org/standard/65694.html

© Universidad Internacional de La Rioja (UNIR)

IMC_01 - Metodología de evaluación de Indicadores para Mejora de la Ciberresiliencia (IMC)

Instituto Nacional de Ciberseguridad (INCIBE). (2020). *IMC_01 - Metodología de evaluación de Indicadores para Mejora de la Ciberresiliencia (IMC).* INCIBE. https://www.incibe-cert.es/sites/default/files/contenidos/guias/IMC/imc_01_metodologia-evaluacion.pdf

El objetivo de la presente metodología de evaluación de Indicadores para la Mejora de la Ciberresiliencia (IMC) para sistemas de control industrial y sistemas TIC es ayudar a todas las partes interesadas en medir sus capacidades de ciberresiliencia y disponer de una metodología que permita conocer el grado de madurez de sus controles para anticipar, resistir, recuperarse y evolucionar frente a condiciones adversas, estrés o ataques contra los recursos cibernéticos de una organización.

© Universidad Internacional de La Rioja (UNIR)

IMC_02 - Diccionario de Indicadores para Mejora de la Ciberresiliencia (IMC)

Instituto Nacional de Ciberseguridad (INCIBE). (2020). *IMC_02 - Diccionario de Indicadores para Mejora de la Ciberresiliencia (IMC).* INCIBE. https://www.incibe-cert.es/sites/default/files/contenidos/guias/IMC/imc_02_diccionario-indicadores.pdf

Este diccionario describe los indicadores para la mejora de la ciberresiliencia (IMC) en organizaciones y empresas de sectores industriales e infraestructuras críticas industriales con respecto a ámbitos de *IT (Information Technology)* y *OT (Operation Technology).* Estos indicadores se pueden usar para definir consultas de madurez —para cada empresa, sector o grupo de empresas— con las que determinar los niveles de resiliencia (para los objetivos: Anticipar, Resistir, Recuperar y Evolucionar) correspondientes a la provisión de sus servicios esenciales. Los distintos indicadores se valoran siguiendo los criterios indicados en la metodología de evaluación descrita en el documento: *IMC_01 - Metodología de evaluación de Indicadores para Mejora de la Ciberresiliencia.*

© Universidad Internacional de La Rioja (UNIR)

Guía de seguridad (CCN-STIC-815) esquema nacional de seguridad métricas e indicadores

Centro Criptológico Nacional (CCN). (2014, febrero). *Guía de seguridad (CCN-STIC-815): esquema nacional de seguridad métricas e indicadores.* https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/525-ccn-stic-815-indicadores-y-metricas-en-el-ens/file.html

Esta guía persigue varios objetivos:

- Proponer un conjunto de datos a registrar del sistema de información a fin de poder derivar métricas posteriormente, tanto locales del sistema, como del conjunto de la Administración.
- Proponer un conjunto reducido de métricas o indicadores para caracterizar la posición del sistema de información en materia de seguridad de la información.
- Proponer un conjunto de métricas o indicadores para materializar el reporte anual requerido por el artículo 35.
- Proponer cuadros de mando para escenarios típicos.
- Establecer las pautas para que cada organismo extienda los indicadores que convengan en cada momento a sus necesidades.

© Universidad Internacional de La Rioja (UNIR)

Guía de seguridad de áreas críticas para la computación en la nube v4.0

Cloud Security Alliance. (2018). *Guía de seguridad de áreas críticas para la computación en la nube v. 4.0.* https://www.ismsforum.es/ficheros/descargas/csaguide-v4-es-20181525872082.pdf

El aumento de la computación en la nube como una tecnología en constante evolución trae consigo una serie de oportunidades y desafíos. Con este documento, nuestro objetivo es proporcionar tanto orientación como inspiración para respaldar los objetivos comerciales, mientras se gestionan y mitigan los riesgos asociados con la adopción de la tecnología de computación en la nube.

© Universidad Internacional de La Rioja (UNIR)

Modelo para la mitigación de vulnerabilidades informáticas en los servicios web

Remache, E. M. (2018). *Modelo para la mitigación de vulnerabilidades informáticas en los servicios web de la Pontificia Universidad Católica del Ecuador Ambato* [Proyecto de Investigación para Máster]. Pontificia Universidad Católica del Ecuador. https://repositorio.pucesa.edu.ec/bitstream/123456789/2474/1/76736.pdf

Con una tecnología cambiante, con vulnerabilidades que se descubren día a día que permiten nuevas formas de ataques cibernéticos, se hace imprescindible el tener los servicios web de la institución asegurados y evitar daños futuros. Es así como, con la ayuda de la metodología de gestión de riesgos Magerit V3, se definió como un modelo acoplado que permite mitigar las vulnerabilidades informáticas en los servicios web de la Pontificia Universidad Católica del Ecuador Ambato, para la toma de decisiones y prevenir que los servicios sean atacados o vulnerados.

El modelo propuesto inicia con la identificación de los servicios y activos informáticos, para luego hacer un análisis de los riesgos y determinar el daño que causarían a la organización.

© Universidad Internacional de La Rioja (UNIR)

Test

1. Cuál de las siguientes no es una característica de un indicador:

A. Objetivo.

B. Realista.

C. Especifico.

D. Medible.

2. ¿Cuál de las siguientes afirmaciones es correcta?

A. Una métrica es una estimación del grado en que un sistema, componente o proceso posee un atributo dado.

B. Una métrica es una medida cualitativa o cuantitativa del grado en que un sistema, componente o proceso posee un atributo dado.

C. Una métrica es una medida cuantitativa del grado en que un sistema, componente o proceso posee un atributo dado.

D. Una métrica es una medida cualitativa del grado en que un sistema, componente o proceso posee un atributo dado.

3. Los indicadores como elemento clave que da soporte a la toma de decisiones, nos permite:

A. Medir la evolución de amenazas actuales y emergentes.

B. Medir la efectividad de las salvaguardas implantadas.

C. Medir la capacidad o habilidad de la organización en las tareas de seguridad

D. Todas son ciertas.

© Universidad Internacional de La Rioja (UNIR)

4. Las salvaguardas preventivas:

A. Actúan reduciendo el impacto.

B. Actúan reduciendo la probabilidad de materialización de las amenazas.

C. Actúan reduciendo el número de amenazas.

D. Actúan reduciendo la probabilidad de materialización del riesgo.

5. Para poder determinar la eficacia de una salvaguarda:

A. Es necesario conocer su grado de implantación.

B. No es necesario conocer su grado de implantación.

C. Es necesario analizar la probabilidad de materialización de una amenaza.

D. Es necesario analizar el impacto.

6. Para diseñar e implantar un conjunto de métricas e indicadores de riesgos, no es necesario:

A. Determinar lo atributos a medir.

B. Determinar las entidades a medir.

C. Determinar los conceptos medibles.

D. Definir las medidas.

7. Realizar mediciones persigue, entre otros, los siguientes objetivos:

A. Implementar mayor número de salvaguardas.

B. Evaluar la peligrosidad de las amenazas actuales y emergentes.

C. Mejorar la minimización del riesgo.

D. Todas son ciertas.

© Universidad Internacional de La Rioja (UNIR)

8. A la hora de elaboran las métricas es necesario definir:

A. Los métodos de análisis, la escala y los indicadores.

B. Los métodos de medición, la escala y los indicadores.

C. Los métodos de medición, las métricas y los indicadores.

D. Los métodos de análisis, las métricas y los indicadores.

9. Existen métricas:

A. Simples y compuestas.

B. Directas e indirectas.

C. Cualitativas y cuantitativas.

D. De impacto y de riesgo.

10. Cuando hablamos de indicadores, ¿a qué nos referimos con una meta?

A. Los resultados deseados en la implantación de uno o varios objetivos de control/técnicas que son medidos por la métrica.

B. Las acciones que se requieren para alcanzar las medidas fijadas.

C. Los resultados obtenidos en la implantación de uno o varios objetivos de control/técnicas que son medidos por la métrica.

D. Las acciones que se requieren para alcanzar un riesgo aceptable por la Dirección.

© Universidad Internacional de La Rioja (UNIR)